

Esercizio 4: Usare Wireshark per Esaminare il Traffico HTTP e HTTPS

Obiettivi

- **Parte 1** - Catturare e visualizzare il traffico **HTTP**
- **Parte 2** - Catturare e visualizzare il traffico **HTTPS**



Parte 1: HTTP

HyperText Transfer Protocol (HTTP) è un protocollo a livello di applicazione che presenta i dati tramite un browser web. Con HTTP, non c'è salvaguardia per i dati scambiati tra due dispositivi comunicanti. Con HTTPS, viene utilizzata la crittografia tramite un algoritmo matematico. Questo algoritmo nasconde il vero significato dei dati scambiati. Questo viene fatto attraverso l'uso di certificati che possono essere visualizzati più avanti in questo laboratorio. Indipendentemente da HTTP o HTTPS, si raccomanda di scambiare dati solo con siti web di cui ci si fida. Solo perché un sito usa HTTPS non significa che sia un sito affidabile. Gli attori malevoli usano comunemente HTTPS per nascondere le loro attività.

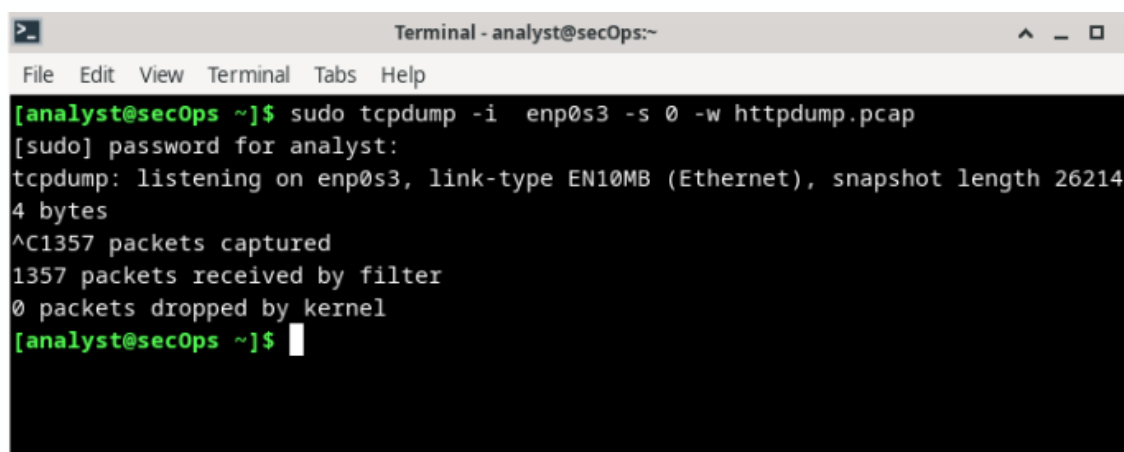
Nella prima parte, userai tcpdump per catturare il contenuto del traffico HTTP. Userai opzioni da riga di comando per salvare il traffico in un file di cattura pacchetti (pcap). Questi record possono poi essere analizzati usando diverse applicazioni che leggono file pcap, incluso Wireshark.

Come primo passo apri un'applicazione terminale e inserisci il comando ip address.

```
[analyst@secOps ~]$ ip address
```

Mentre sei nell'applicazione terminale, inserisci il comando **sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap**. Inserisci la password cyberops per l'utente analyst quando richiesto. Sono state controllate le interfacce di rete e i rispettivi indirizzi IP, per poi lanciare tcpdump in ascolto.

Viene intercettato il traffico dal sito web <http://testphp.vulnweb.com/login.php>. Viene effettuato un tentativo di accesso prima di chiudere il browser e l'ascolto del tcpdump, quindi viene aperto il file pcap.



```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), snapshot length 262144 bytes
^C1357 packets captured
1357 packets received by filter
0 packets dropped by kernel
[analyst@secOps ~]$
```

Questo comando avvia **tcpdump** e registra il traffico di rete sull'interfaccia **enp0s3**.

L'opzione di comando **-i** ti permette di specificare l'interfaccia. Se non specificato, tcpdump catturerà tutto il traffico su tutte le interfacce.

L'opzione di comando **-s** specifica la lunghezza dello snapshot per ogni pacchetto. Dovresti limitare `snaplen` al numero più **piccolo** che catturerà le informazioni del protocollo a cui sei interessato.

Impostare `snaplen` a 0 lo imposta al default di **262144**, per compatibilità retroattiva con recenti versioni più vecchie di tcpdump. L'opzione di comando **-w** è usata per scrivere il risultato del comando tcpdump su un file. Aggiungere l'estensione **.pcap** assicura che sistemi operativi e applicazioni saranno in grado di leggere il file. Tutto il traffico registrato sarà stampato nel file **httpdump.pcap** nella directory home dell'utente analyst.

Usa le pagine man per tcpdump per determinare l'uso delle opzioni di comando **-s** e **-w**. Apri un browser web dalla barra di avvio all'interno della CyberOps Workstation e naviga su **<http://testphp.vulnweb.com/login.php>** Poiché questo sito web usa HTTP, il traffico non è crittografato. Fai clic sul campo Password per vedere apparire l'avviso.

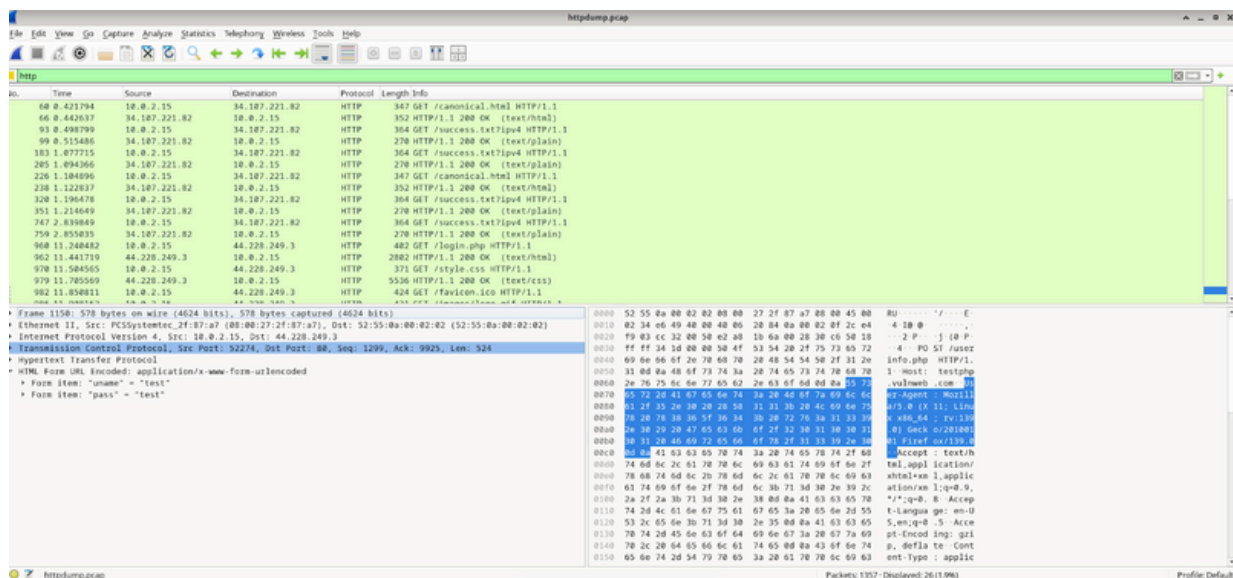
Inserisci un nome utente **Admin** con una password **Admin** e fai clic su Login.

f. Chiudi il browser web.

g. Torna alla finestra del terminale dove tcpdump è in esecuzione. Inserisci CTRL.C per fermare la cattura dei pacchetti.

Passo 3- Visualizzare la cattura HTTP. Il tcpdump, eseguito nel passo precedente, ha stampato l'output su un file chiamato **httpdump.pcap**. Questo file si trova nella directory home per l'utente analyst.

Nell'applicazione Wireshark, **filtra** per http e fai clic su Applica.



Sfoglia i diversi messaggi HTTP e seleziona il messaggio POST.

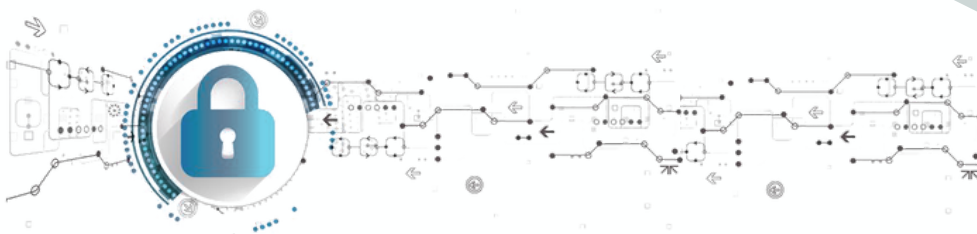
.Nella finestra inferiore, viene visualizzato il messaggio. Espandi la sezione **HTML Form URL Encoded: application/x-www-form-urlencoded**.



Quali due informazioni vengono visualizzate?

Esaminando il messaggio **POST** si può notare che username e password non sono crittografati e ci vengono mostrati in chiaro:

- **Username = test**
- **Password = test**



Parte 2 - Catturare e Visualizzare il Traffico HTTPS

Ora userai **tcpdump** dalla riga di comando di una workstation Linux per catturare il traffico HTTPS. Dopo aver avviato tcpdump, genererai traffico **HTTPS** mentre tcpdump registra il contenuto del traffico di rete. Questi record saranno nuovamente analizzati usando **Wireshark**.

Passo 1- Avviare tcpdump all'interno di un terminale. a. Mentre sei nell'applicazione terminale, inserisci il comando `sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap`. Inserisci la password **cyberops** per l'utente **analyst** quando richiesto.

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

Questo comando avvierà tcpdump e **registrerà** il traffico di rete sull'interfaccia **enp0s3** della workstation Linux. Se la tua interfaccia è diversa da enp0s3, modificala quando usi il comando sopra.

Tutto il traffico registrato sarà stampato nel file **httpsdump.pcap** nella directory home dell'utente **analyst**.

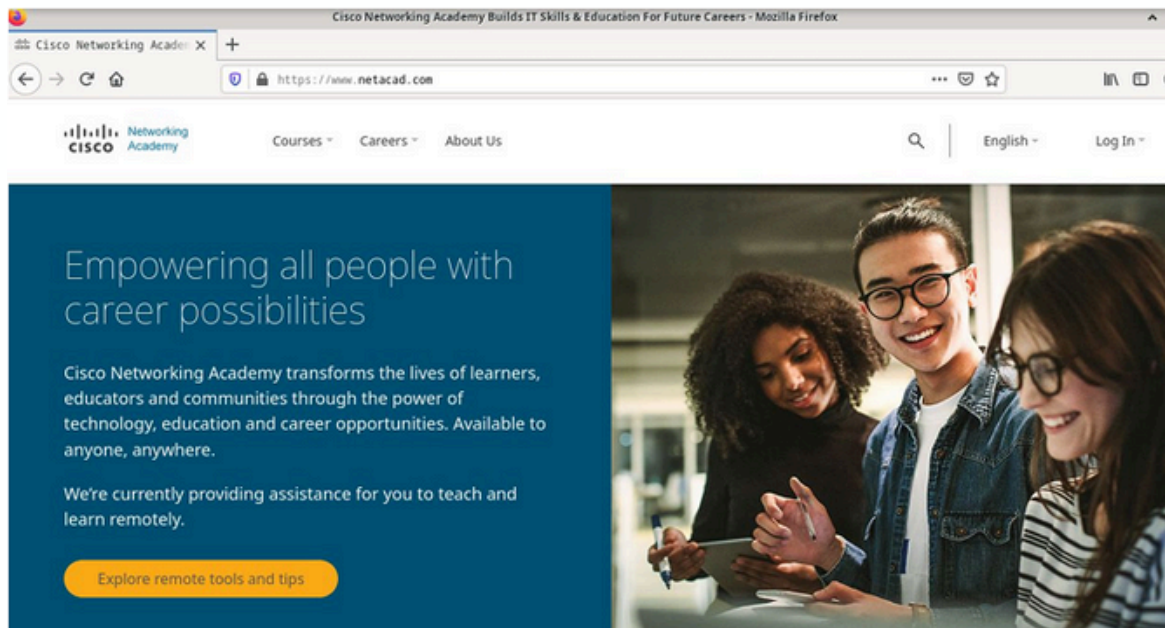
Apri un browser web dalla barra di avvio all'interno della VM CyberOps Workstation. Naviga a **www.netacad.com**. Nota: Se ricevi una pagina web "Connessione sicura non riuscita", probabilmente significa che la data e l'ora sono errate. **Aggiorna** il giorno e l'ora con il seguente comando, cambiando al giorno e all'ora correnti:

```
[analyst@secOps ~]$ sudo date -s "12 MAY 2020 21:38:20"
```



Cosa noti riguardo all'URL del sito web?

Quel che si nota dall'URL della pagina è che, a differenza di testphp, utilizza una connessione **sicura** e protetta con certificazione digitale (**HTTPS**).



Inserisci il tuo **nome utente** e **password NetAcad**. Fai clic su Successivo.

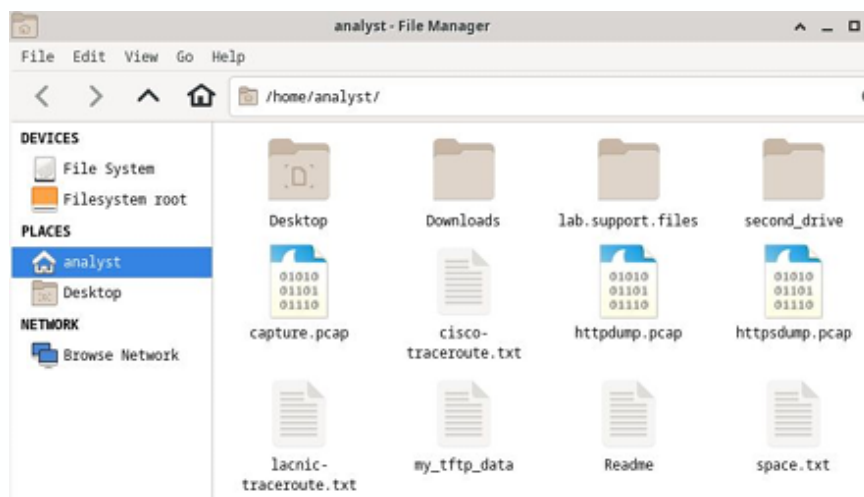


Chiudi il browser web nella VM. e Torna alla finestra del terminale dove tcpdump è in esecuzione. Inserisci CTRL.C per fermare la cattura dei pacchetti

Passo 2- Visualizzare la cattura HTTPS.

Il **tcpdump** eseguito nel Passo 1 ha stampato l'output su un file chiamato **httpsdump.pcap**. Questo file si trova nella directory home per l'utente analyst.

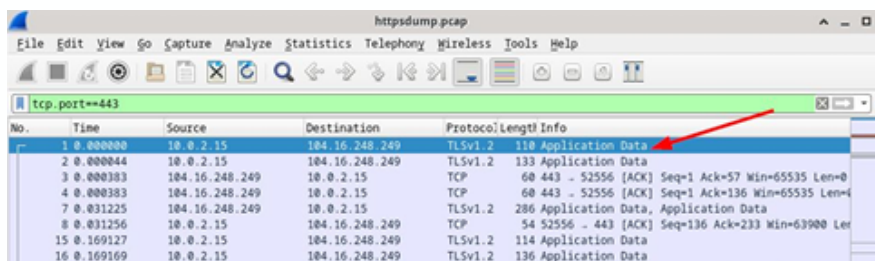
a. Fai clic sull'icona **Filesystem** sul desktop e naviga alla cartella home per l'utente analyst. Apri il file **httpsdump.pcap**.



b. Nell'applicazione Wireshark, espandi verticalmente la finestra di cattura e poi filtra per traffico HTTPS tramite la porta **443**. Inserisci **tcp.port==443** come filtro, e fai clic su Applica.



Sfoglia i diversi messaggi HTTPS e seleziona un messaggio **Application Data**.



Nella finestra inferiore, viene visualizzato il messaggio.



Cosa ha sostituito la sezione HTTP che era nel file di cattura precedente?

Effettuato il **login** su netacad.com e creato il file **php**, quindi viene aperto ed esaminato

```
▶ Frame 1150: 578 bytes on wire (4624 bits), 578 bytes captured (4624 bits)
▶ Ethernet II, Src: PCSSystemtec_2f:87:a7 (08:00:27:2f:87:a7), Dst: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
▶ Internet Protocol Version 4, Src: 10.0.2.15, Dst: 44.228.249.3
▶ Transmission Control Protocol, Src Port: 52274, Dst Port: 80, Seq: 1299, Ack: 9925, Len: 524
▶ Hypertext Transfer Protocol
▶ HTML Form URL Encoded: application/x-www-form-urlencoded
```

Cattura HTTP

```
▶ Frame 90: 153 bytes on wire (1224 bits), 153 bytes captured (1224 bits)
▶ Ethernet II, Src: PCSSystemtec_2f:87:a7 (08:00:27:2f:87:a7), Dst: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
▶ Internet Protocol Version 4, Src: 10.0.2.15, Dst: 151.101.1.91
▶ Transmission Control Protocol, Src Port: 57752, Dst Port: 443, Seq: 316, Ack: 3283, Len: 99
▼ Transport Layer Security
  ▶ TLSv1.2 Record Layer: Application Data Protocol: HyperText Transfer Protocol 2
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 94
    Encrypted Application Data: 000000000000000019d5cca5f00d1118690588ddca4618e3d2d3aab1171f36c0a4979d8b1e49...
    [Application Data Protocol: HyperText Transfer Protocol 2]
```

Cattura HTTPS

“hypertext transfer protocol” e “HTML form URL Encoded” sono stati **sostituiti** in HTTPS dal “Transport Layer Security”, che ci comunica che il TLS è **attivo** (i dati vengono cifrati) e la sua versione.

e. Espandi completamente la sezione **Secure Sockets Layer**.

```
▶ Frame 1: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)
▶ Ethernet II, Src: PcsCompu_82:75:df (08:00:27:82:75:df), Dst: RealtekU_12:35:02 (52:54:00:12:35:02)
▶ Internet Protocol Version 4, Src: 10.0.2.15, Dst: 104.16.248.249
▶ Transmission Control Protocol, Src Port: 52556, Dst Port: 443, Seq: 1, Ack: 1, Len: 56
▼ Transport Layer Security
  ▶ TLSv1.2 Record Layer: Application Data Protocol: http-over-tls
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 51
    Encrypted Application Data: 7fa9037731c6e38e6213aacc15a@a7281f94046fdb237be9...
```



I dati dell'applicazione sono in formato plaintext o leggibile?

Controllando Encrypted Application Data i dati non sono nè in plaintext, nè leggibili, ma cifrati.



Quali sono i vantaggi dell'uso di HTTPS invece di HTTP?

Vantaggi dell'uso HTTPS rispetto all' HTTP:

1. In HTTPS i dati viaggiano **cifrati**

HTTPS

```
Transport Layer Security
  TLSv1.2 Record Layer: Application Data Protocol: HyperText Transfer Protocol 2
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 94
    Encrypted Application Data: 0000000000000019d5cca5fead118690580ddca4618e3d2d3aab1171f36c0a4979d8b1e4991ec7c535c...
    [Application Data Protocol: HyperText Transfer Protocol 2]
```

HTTP

```
HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "uname" = "test"
  Form item: "pass" = "test"
```

2. **Autenticazione** del server (certificato TLS)

3. **Integrità** (rileva le manomissioni).



Tutti i siti web che usano HTTPS sono considerati affidabili?

HTTPS **non è certezza di sicurezza**, anzi gli attaccanti lo possono sfruttare come BIAS delle vittime per attuare le loro truffe (ingegneria sociale).